

Security+ 2.4 · Password Attacks

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.4 — Password Attacks (7:15)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Password attack: password spraying (UMA senha comum MUITOS usuários — evita lockout); credential stuffing (senhas VAZADAS reusadas); brute force (todas as combinações — rápido mas detectável); dictionary (lista de palavras); rainbow table (hash pré-computados — MORTO pelo SALTING). Defesa: MFA, manager de senha, lockout, salt + argon2/bcrypt, monitorar login anômalo.

Highlights que a prova cobra

- Password spraying: 1 senha fraca contra muitos usuários (discreto)
- Brute force = tentar tudo; dictionary = lista de palavras
- Rainbow table = hash pré-computada — MORTA pelo SALTING
- Reusa de senha vazada em outros sites = credential stuffing

Dicas de prova & Cenários Típicos

- 'single weak password tried against many accounts' = password spraying
- 'pre-computed hash table' = rainbow table (defesa: salting)

Cenário clássico de exame: Cenário: 'atacante usa a senha Password123! em todos os usuários do domínio, evitando lockout' = password spraying.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.4 — Password Attacks)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **MFA:** Multi-Factor Authentication: Autenticação multifator exigindo dois ou mais fatores distintos das categorias: algo que você sabe, algo que você tem, algo que você é, algo que você faz ou algum lugar onde você está.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Atacante testa senhas VAZADAS de um site em VÁRIOS outros sites (reúso de senha):

- A) Credential stuffing
- B) Força bruta pura
- C) Rainbow table
- D) Vishing

2. MFA exige pelo menos dois fatores de autenticação. Qual combinação representa autenticação de múltiplos fatores genuína?

- A) Senha + PIN
- B) Senha + Token físico
- C) Dois tipos de biometria
- D) Pergunta de segurança + Senha

3. A forma correta de ARMAZENAR senhas de usuários:

- A)** Hash com salt (ex: bcrypt)
- B)** Criptografia AES reversível
- C)** Texto claro protegido por firewall
- D)** Base64

4. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Password spraying: 1 senha fraca contra muitos usuários (discreto)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Password spraying: 1 senha fraca contra muitos usuários (discreto)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Brute force = tentar tudo; dictionary = lista de palavras'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Brute force = tentar tudo; dictionary = lista de palavras...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Rainbow table = hash pré-computada — MORTA pelo SALTING'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Rainbow table = hash pré-computada — MORTA pelo SALTING...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Reusa de senha vazada em outros sites = credential stuffing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Reusa de senha vazada em outros sites = credential stuffing...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'single weak password tried against many accounts' = password spraying'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'single weak password tried against many accounts' = password spraying...

9. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'pre-computed hash table' = rainbow table (defesa: salting). Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'pre-computed hash table' = rainbow table (defesa: salting)...

10. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'atacante usa a senha Password123! em todos os usuários do domínio, evitando lockout' = password spraying.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário: 'atacante usa a senha Password123! em todos os usuários do domínio...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Credential stuffing.

✓ **Por que está certa:** Credential stuffing é um ataque cibernético no qual o atacante utiliza listas de credenciais (pares de usuário e senha) obtidas de violações de dados em um site para tentar autenticar em vários outros sites, explorando a prática comum de reúso de senhas. O ataque é automatizado e depende de grandes volumes de credenciais vazadas. Diferencia-se da força bruta pura porque não tenta adivinhar senhas, mas usa combinações já conhecidas. É um tópico do domínio de Ameaças, Vulnerabilidades e Mitigação da Security+ (SY0-701), objetivo 2.4, que aborda técnicas de ataque.

✗ **Por que as outras estão erradas:**

- *Força bruta pura:* Força bruta pura é um método de ataque que tenta exaustivamente todas as combinações possíveis de caracteres até encontrar a senha correta. No credential stuffing, o atacante não testa combinações aleatórias; ele usa credenciais previamente vazadas e válidas em outro contexto. A força bruta é computacionalmente intensiva e facilmente detectável por bloqueios de conta, enquanto o credential stuffing explora a reutilização de senhas e pode ser mais furtivo, pois as credenciais são legítimas. Portanto, a força bruta pura não descreve o cenário de teste de senhas vazadas em vários sites.
- *Rainbow table:* Rainbow table é uma técnica de quebra de hash que utiliza tabelas pré-computadas de hashes de senhas para reverter funções de hash criptográficas. Ela é usada quando o atacante obtém hashes de senhas e deseja descobrir as senhas em texto claro. No entanto, o enunciado descreve o uso de senhas já vazadas (em texto claro ou já quebradas) para autenticar em outros sites, não a quebra de hashes. Rainbow tables não se aplicam diretamente ao credential stuffing, que não requer quebra de criptografia, mas sim a exploração de reúso de credenciais.
- *Vishing:* Vishing é uma forma de engenharia social que utiliza chamadas telefônicas ou mensagens de voz para enganar vítimas e obter informações confidenciais, como senhas ou dados financeiros. Não envolve o teste automatizado de credenciais vazadas em múltiplos sites. O cenário descrito é claramente um ataque técnico de automação, não uma interação humana de persuasão. Portanto, vishing não se aplica ao contexto de credential stuffing, que é um ataque em massa baseado em listas de credenciais.

2) B — Senha + Token físico.

✓ **Por que está certa:** A combinação ****Senha + Token físico**** representa autenticação de múltiplos fatores genuína porque combina dois fatores distintos: algo que você sabe (a senha) e algo que você possui (o token físico, como um smart card, chave USB ou dispositivo gerador de OTP). O MFA requer a combinação de pelo menos dois dos três fatores clássicos: conhecimento (algo que você sabe), posse (algo que você tem) e inerência (algo que você é). No syllabus da CompTIA Security+ (SY0-701), essa distinção é fundamental para evitar falsos MFA, como senha + PIN, que são ambos do mesmo fator (conhecimento).

✗ **Por que as outras estão erradas:**

- *Senha + PIN:* Senha e PIN são ambos baseados em conhecimento; ou seja, representam o mesmo fator de autenticação (algo que você sabe). Mesmo que sejam dois segredos diferentes, não configuram MFA genuíno, pois não há combinação de fatores distintos. Um atacante que obtiver ambos (por exemplo, via keylogger ou engenharia social) compromete a autenticação. Para ser MFA, é necessário adicionar um fator de posse ou inerência. Portanto, essa opção é incorreta.
- *Dois tipos de biometria:* Dois tipos de biometria (por exemplo, impressão digital e reconhecimento facial) pertencem ao mesmo fator: inerência (algo que você é). Embora sejam métodos distintos, não constituem MFA genuíno, pois não combinam fatores diferentes. O MFA

exige a combinação de categorias distintas (conhecimento, posse, inerência). Além disso, biometrias podem ser problemáticas se comprometidas (uma vez vazadas, não podem ser alteradas). Logo, essa opção não atende ao requisito de múltiplos fatores.

- *Pergunta de segurança + Senha*: Perguntas de segurança e senha são ambos baseados em conhecimento (algo que você sabe). A pergunta de segurança é frequentemente usada como um segundo passo, mas ainda pertence ao mesmo fator. Portanto, não é MFA genuíno. Além disso, perguntas de segurança são vulneráveis a ataques de engenharia social e podem ser descobertas em redes sociais. Para ser MFA, seria necessário adicionar um fator de posse ou inerência. Assim, essa combinação está incorreta.

3) A — Hash com salt (ex: bcrypt).

- ✓ **Por que está certa:** O armazenamento seguro de senhas de usuários exige o uso de funções de hash criptográfico lentas e resistentes a ataques de força bruta, como bcrypt, scrypt ou Argon2, combinadas com um salt único e aleatório por usuário. O salt impede ataques de tabela pré-computada (rainbow tables) e garante que senhas iguais produzam hashes diferentes. Funções como bcrypt são projetadas para serem computacionalmente custosas, ajustáveis por fator de custo, dificultando ataques de dicionário e força bruta offline. O hash é unidirecional, então mesmo que o banco de dados seja comprometido, o atacante não obtém a senha original diretamente, apenas o hash, que deve ser quebrado individualmente.

✗ Por que as outras estão erradas:

- *Criptografia AES reversível*: AES é uma cifra simétrica reversível: com a chave correta, o texto cifrado pode ser decifrado de volta ao texto claro. Se as senhas forem armazenadas cifradas com AES, qualquer pessoa que obtenha a chave de criptografia (por exemplo, através de comprometimento do servidor de aplicação ou do banco de dados) pode recuperar todas as senhas originais. Isso viola o princípio de que nem mesmo os administradores do sistema devem conhecer as senhas dos usuários. Além disso, a gestão da chave AES adiciona complexidade e risco desnecessários para um dado que nunca precisa ser recuperado em texto claro.
- *Texto claro protegido por firewall*: Armazenar senhas em texto claro significa que elas estão legíveis no banco de dados ou arquivo de configuração. Um firewall protege contra acessos não autorizados pela rede, mas não impede que um atacante que explore uma vulnerabilidade na aplicação, um insider malicioso ou um administrador com acesso ao banco de dados leia diretamente as senhas. A segurança em profundidade exige que o dado sensível seja protegido em repouso, independentemente de controles perimetrais. Firewall é um controle de rede, não de armazenamento de credenciais.
- *Base64*: Base64 é uma codificação reversível sem chave, frequentemente usada para representar dados binários em texto. Não oferece confidencialidade alguma: qualquer pessoa pode decodificar uma string Base64 instantaneamente. Armazenar senhas em Base64 é funcionalmente equivalente a armazená-las em texto claro, apenas com uma aparência ofuscada. Não há salt, não há custo computacional e não há resistência a ataques. É uma prática completamente inadequada para proteção de credenciais.

4) B — Implementar a solução correspondente: Password spraying: 1 senha fraca contra muitos usuários (discreto)....

- ✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): Password spraying: 1 senha fraca contra muitos usuários (discreto).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para

detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: Brute force = tentar tudo; dictionary = lista de palavras....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): Brute force = tentar tudo; dictionary = lista de palavras.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: Rainbow table = hash pré-computada — MORTA pelo SALTING....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): Rainbow table = hash pré-computada — MORTA pelo SALTING.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: Reusa de senha vazada em outros sites = credential stuffing....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): Reusa de senha vazada em outros sites = credential stuffing.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: 'single weak password tried against many accounts' = password spraying....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): 'single weak password tried against many accounts' = password spraying.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: 'pre-computed hash table' = rainbow table (defesa: salting)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): 'pre-computed hash table' = rainbow table (defesa: salting).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: Cenário: 'atacante usa a senha Password123! em todos os usuários do domínio....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): Cenário: 'atacante usa a senha Password123! em todos os usuários do domínio, evitando lockout' = password spraying..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.